

CYS401: Fundamentals of Cybersecurity

Class Activity 4

SCENARIO:

Jack Doe is the Community Liaison Officer for 3D Media Comm. Ltd based in Perth, Western Australia. It is assumed that Jack carries a laptop, smart phone and Surface Pro 4 everywhere he goes. His laptop specifications include an Intel i7 CPU, 16GB RAM, and Windows 10 Professional with the latest update until June 2020. Jack uses Microsoft Office Professional 2019 for all his business needs. Jack connects his laptop to the company network, whilst occasionally he uses internet cafes networks when he leaves his laptop in his car. It is understood that Jack does not use third party firewalls, anti-virus software, encryption or authentication mechanisms.

TASK:

Information systems and networks throughout the world are swiftly expanding, meaning information security within companies is a priority. The aims of security crucially need to be understood, for the risks and attacks associated with information systems and networks to mitigated. Security professionals refer to the objectives of security as confidentiality, integrity, availability, authenticity and access control. Each of these objectives of security have different attacks, risks, impacts and countermeasures.

1. For the given case study, review and evaluate the objectives of security (Confidentiality, Integrity, Availability, Authenticity and Access Control) in relation to the work environment of Jack Doe, at 3D Media Comm.

- **Confidentiality**

Confidentiality ensures that sensitive information is only accessible to authorized individuals. Jack Doe handles company information using his laptop, smartphone and Surface Pro 4. Since he does not use encryption or strong authentication mechanisms and sometimes connects to public internet-cafe networks, confidential company information could be exposed. If one of his devices is stolen or if his network traffic is intercepted, an unauthorized person may gain access to business documents, emails, credentials or other sensitive information.

- **Integrity**

Integrity ensures that information remains accurate, complete and protected against unauthorized modification. Jack's use of different network environments increases the possibility that malware or an attacker could alter information stored on his devices. If his laptop becomes infected while connected to an untrusted network and is later connected to the

company network, malicious or modified files could also affect company resources. Loss of integrity could therefore result in inaccurate records, altered documents or unauthorized changes to company information.

- **Availability**

Availability ensures that authorized users can access systems, services and information whenever they are required. Jack depends on his devices and network connections to perform his responsibilities as Community Liaison Officer. Malware, ransomware, hardware failure, device theft or network attacks could prevent him from accessing important company information. This could interrupt his work and potentially affect the operations of 3D Media Comm.

- **Authenticity**

Authenticity ensures that users, devices and communications are genuine and can be verified. Jack does not use appropriate authentication mechanisms, which increases the possibility of someone impersonating him or accessing company services using stolen credentials. An attacker could potentially send messages, access documents or perform activities while pretending to be Jack, making it difficult for the company to verify whether activities are legitimate.

- **Access Control**

Access control determines which users are permitted to access particular systems, information and resources and what actions they are allowed to perform. Jack's lack of appropriate authentication and security mechanisms increases the possibility of unauthorized access. If his device or credentials are compromised, an attacker could potentially access company information or network resources. Appropriate access control is therefore necessary to ensure Jack can only access resources required for his role and unauthorized users cannot access company systems.

2. Clearly mention security countermeasures for each cybersecurity objective in Part 1.

- **Confidentiality**

To protect confidentiality, Jack should use full-disk encryption such as BitLocker on his laptop and other supported devices. Strong passwords and multi-factor authentication should be required to prevent unauthorized access. When using public or untrusted networks, Jack should connect through a trusted VPN so that network traffic is encrypted. Automatic screen locking should also be enabled to protect information when devices are left unattended.

- **Integrity**

Jack should use endpoint protection and anti-malware software to detect malicious programs that could modify company information. Windows, Microsoft Office and other applications should be regularly patched and updated. File permissions should restrict unauthorized modifications, while logging and auditing should be used to identify suspicious changes. Regular backups should also be maintained so that trusted versions of files can be restored.

- **Availability**

Regular backups should be created and tested so that important information can be recovered following ransomware, hardware failure or accidental loss. Jack's devices should remain patched and protected by endpoint security software to reduce the likelihood of attacks that make systems unavailable. The company should also maintain disaster-recovery procedures and alternative methods of accessing critical services when primary systems are unavailable.

- **Authenticity**

Multi-factor authentication should be implemented for Jack's company accounts so that a stolen password alone cannot provide access. Strong and unique credentials should be required. Digital certificates and secure authentication protocols can also be used where appropriate to verify legitimate devices and services. Jack should receive phishing-awareness training to help him recognize attempts to steal his credentials or impersonate trusted organizations.

- **Access Control**

3D Media Comm. should implement role-based access control and the principle of least privilege so that Jack only has access to information and systems required for his responsibilities. Strong device authentication should be required, and devices should automatically lock after periods of inactivity. User permissions should also be regularly reviewed and unnecessary privileges removed.

3. What types of threats/ attack could target Jack Doe working environment while connecting with different network domains. Also suggest **TWO** countermeasures for each identified attack.

1) **Man-in-the-Middle (MITM) Attack**

When Jack connects to an internet-cafe or other public network, an attacker could intercept communications between his device and the network. The attacker may attempt to monitor or manipulate information being transmitted.

Countermeasures:

1. Use a trusted VPN whenever connecting to an untrusted network.
2. Use encrypted HTTPS/TLS connections and never ignore certificate warnings.

2) Evil Twin / Rogue Wi-Fi Attack

An attacker could create a fake wireless access point with a name similar to the legitimate internet-cafe network. If Jack connects to the fake network, the attacker could monitor or manipulate his network traffic.

Countermeasures:

1. Verify the correct Wi-Fi network before connecting.
2. Disable automatic connection to Wi-Fi networks and use a VPN on public networks.

3) Malware / Trojan Attack

Jack could accidentally download malware through malicious websites, email attachments or infected files. Malware could steal information, modify files or provide an attacker with unauthorized access to his device.

Countermeasures:

1. Enable and maintain appropriate endpoint protection/anti-malware software.
2. Regularly update Windows, Microsoft Office, browsers and other applications.

4) Phishing / Credential Theft

Attackers could send Jack fraudulent emails or direct him to fake login pages designed to steal his company username and password.

Countermeasures:

1. Enable multi-factor authentication for company accounts.
2. Provide phishing-awareness training so suspicious emails, links and login requests can be identified.

5) Ransomware

Ransomware could infect Jack's laptop and encrypt his business files, preventing him from accessing them. If the infected laptop connects to company resources, accessible network files could potentially also be affected.

Countermeasures:

1. Maintain regular and tested offline or isolated backups.
2. Use endpoint protection and restrict unnecessary user privileges and application execution.

6) Password/Credential Attacks

Attackers could attempt to guess Jack's password, use previously leaked credentials, or obtain his credentials through other attacks and use them to access company services.

Countermeasures:

1. Use strong, unique passwords and an approved password manager.
2. Enable multi-factor authentication.

7) Device Theft / Unauthorized Physical Access

Jack carries multiple portable devices and sometimes leaves his laptop in his car. If the laptop is stolen, an attacker could attempt to access locally stored company information or active authenticated sessions.

Countermeasures:

1. Enable full-disk encryption, such as BitLocker.
2. Require strong device authentication and automatic screen locking.

8) Network Scanning and Vulnerability Exploitation

When Jack connects his laptop to an untrusted network, attackers on the same network could scan the device for open ports, exposed services or vulnerabilities and attempt to exploit them.

Countermeasures:

1. Enable and correctly configure the Windows host firewall.
2. Disable unnecessary network services and keep the operating system and applications patched.